



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Chromium: CVE-2026-12012 Use after free Network

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-15
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | Chromium: CVE-2026-12012 Use after free Network - Vulnerability Report

Published: 2026-06-15 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

Chromium: CVE-2026-12012 Use after free Network

1. Executive Summary

CVE-2026-12012 is a high-severity use-after-free vulnerability in the Chromium Network component. Public vulnerability records describe a condition in Google Chrome prior to 149.0.7827.115 that allows an attacker in a privileged network position to potentially exploit heap corruption through malicious network traffic. Microsoft documents the same Chromium issue because Microsoft Edge is Chromium-based and consumes the vulnerable upstream component.

The most important operational point for defenders is exposure breadth. Chromium is a shared browser foundation used by Google Chrome, Microsoft Edge, and multiple downstream Chromium-based browsers. For Lost Boys Cyber clients, the priority is not limited to internet-facing servers; the exposed asset class is user endpoints, privileged administrator workstations, VDI pools, kiosk systems, jump hosts, and any environment where browser traffic crosses untrusted or adversary-controllable network infrastructure.

As of this report, the public evidence reviewed does not show confirmed exploitation in the wild or CISA Known Exploited Vulnerabilities catalog inclusion for CVE-2026-12012. The vulnerability still warrants urgent patch governance because successful exploitation would occur before endpoint telemetry can reliably observe the memory-corruption primitive, and because network-positioned attackers can target browsing sessions without requiring the victim to install software or open a traditional attachment.

Priority	Defender Decision	Lost Boys Cyber Assessment
1	Patch Chrome and Edge to fixed builds or later	Immediate action; browser auto-update alone should be verified, not assumed
2	Identify unmanaged Chromium-based browsers	High value; third-party Chromium forks can lag vendor patches
3	Hunt for vulnerable browser use across risky networks	Useful for exposure reduction; direct exploit detection is low-confidence
4	Increase attention to browser crash and network anomalies	Supportive signal only; not a substitute for patching

2. Intelligence Requirement

This report answers the following intelligence requirement: What is CVE-2026-12012, which environments are exposed, what confidence should defenders place in the available sources, and what actions should security teams take before public exploit details mature?

Requirement	Answer
Primary stakeholder	Security operations, vulnerability management, endpoint engineering, IT operations
Decision supported	Patch prioritization and targeted exposure hunting for Chromium-based browsers
Time horizon	Immediate remediation window: 24-72 hours for managed endpoints; seven days for lower-risk unmanaged inventory where compensating controls exist
Key uncertainty	Google restricts detailed bug information until most users receive fixes; exploit mechanics are inferred from the vulnerability class, component, and CVSS vector rather than a public proof-of-concept

Confidence	High for affected product and fix information; medium for exploitation-path details beyond the public description
------------	---

Assumption: where Microsoft and Google version language differs by product, this report treats the vendor-supported fixed version for each browser as authoritative. Chrome administrators should target 149.0.7827.115 or later where available, while Microsoft Edge administrators should target 149.0.4022.69 or later per Microsoft Security Update Guide version information.

3. Source Review and Confidence

The source set is sufficient for defensive prioritization. Microsoft provides the Edge-specific update context and confirms customer action is required. Google Chrome Releases provides the upstream Chromium release note, affected component, severity, bug reference, and patched Chrome stable-channel build. NVD provides the public vulnerability description, CWE mapping, publication and modification dates, and CISA-ADP CVSS vector.

Source	Key Contribution	Reliability	Confidence Notes
Microsoft Security Update Guide	Confirms Edge consumption of Chromium, Edge fixed build 149.0.4022.69, and customer action requirement	High	Canonical for Microsoft Edge remediation scope
Google Chrome Releases	Confirms Chrome stable-channel update, Network component, high severity, and restricted bug reference 499182801	High	Canonical upstream Chromium release context; detailed bug remains restricted
NVD CVE detail	Describes privileged-network-position exploitation model, heap corruption outcome, CWE-416, and CISA-ADP CVSS 8.1 vector	High	NVD enrichment was still marked as undergoing reanalysis at review time; use vendor source for remediation details
CISA KEV Catalog check	No matching CVE entry observed at review time	High	Absence from KEV is not proof of non-exploitation; it means no KEV listing was available during this review

Admiralty code for the initial intake is A2: the source is reliable and the information is credible, but exploit details remain intentionally limited because Chromium bug details can remain restricted until user patch uptake is sufficient.

4. Key Findings

Finding	Assessment	Defensive Implication
CVE-2026-12012 is a Chromium Network use-after-free flaw	The weakness class is CWE-416 and the affected component processes remote network content	Treat as a browser memory-safety issue with potential confidentiality, integrity, and availability impact
The public exploitation model requires a privileged network position	NVD/CISA-ADP vector lists AV:N, AC:H, PR:N, UI:N, S:U, C:H/I:H/A:H	Prioritize users on untrusted networks, high-value admin workstations, proxies, captive portals, and locations where TLS interception or hostile gateways exist
Microsoft Edge inherits the vulnerable Chromium component	MSRC states the CVE is included because Edge consumes Chromium	Include both Chrome and Edge in patch validation, especially on Windows enterprise fleets
No public KEV listing was observed during	KEV absence reduces urgency relative to	Patch promptly; do not wait for exploit

review	actively exploited browser zero-days but does not lower technical severity	publication or KEV addition
Direct exploit telemetry is expected to be weak	Browser heap corruption may not produce stable file, process, or network IOCs	Detection engineering should emphasize version compliance, browser crash correlation, risky network paths, and egress/proxy anomaly review

Affected and fixed versions:

Product	Affected State	Fixed / Target Version	Source
Google Chrome	Prior to 149.0.7827.115 per NVD	149.0.7827.114/.115 for Windows and macOS; 149.0.7827.114 for Linux stable-channel release, with .115 cited by NVD for vulnerability boundary	Google Chrome Releases; NVD
Microsoft Edge (Chromium-based)	Edge builds before the Microsoft June 2026 security release	149.0.4022.69, based on Chromium 149.0.7827.115	MSRC
Other Chromium-based browsers	Potentially exposed if they consume vulnerable Chromium code and have not rebased onto a fixed Chromium build	Vendor-specific fixed builds	Inference from Chromium shared-code dependency; validate per vendor

5. Threat Context

CVE-2026-12012 sits in a high-value attack surface: browser networking. The Network component handles traffic parsing, connection management, proxy interaction, caching, protocols, and transport paths that are exposed whenever a browser communicates with remote services. A use-after-free in this area can be attractive because attacker-controlled traffic may be able to influence object lifetime and heap state without a traditional executable payload on disk.

The public vector is notable because it names a privileged network position rather than ordinary website content alone. In practical terms, the attacker may need to influence, intercept, or shape traffic between a victim browser and remote services. Realistic scenarios include hostile Wi-Fi, compromised routers, malicious or compromised proxies, captive portals, rogue enterprise network devices, malicious TLS interception appliances, DNS or traffic-redirection abuse, or attacker presence on a local network segment.

Scenario	Plausible Path	Risk Notes
Hostile Wi-Fi or captive portal	User joins an untrusted network; attacker shapes browser traffic or protocol negotiation	Higher risk for traveling executives, incident responders, sales, and field staff
Compromised proxy or inspection device	Network middleware observes and modifies browser traffic	Particularly relevant where TLS interception is deployed and trust boundaries are complex
Internal adversary on a flat network	Attacker gains a network position near users and targets browser sessions	Requires additional positioning but can scale against many endpoints
High-value workstation targeting	Attacker targets administrator or developer browser traffic	Impact can exceed the browser context if credentials, session tokens, or administrative portals are exposed

MITRE ATT&CK mapping is necessarily conservative because public exploit details are unavailable. The most defensible mappings are technique-level behaviors expected around exploitation and staging rather than a claim about a known campaign.

Technique	Name	Evidence / Rationale
T1189	Drive-by Compromise	Browser exploitation may occur through traffic or content delivered during browsing activity
T1557	Adversary-in-the-Middle	The public description requires a privileged network position, consistent with traffic interception or manipulation prerequisites
T1203	Exploitation for Client Execution	Browser memory corruption can enable code execution in the client context if exploitation succeeds
T1059	Command and Scripting Interpreter	Post-exploitation follow-on only; include in hunts when suspicious browser child processes appear
T1105	Ingress Tool Transfer	Post-exploitation follow-on only; include in hunts for downloads or payload retrieval following anomalous browser behavior

6. Detection and Hunting

Direct network-signature detection for CVE-2026-12012 is not recommended as the primary control at this stage. The restricted Chromium bug details mean there is no reliable public byte pattern, protocol field, or exploit payload to encode into IDS logic. The highest-confidence detection strategy is layered: prove patch compliance, identify vulnerable browser use on risky networks, correlate abnormal browser crashes with unusual network sessions, and alert on post-exploitation behaviors such as suspicious child processes or unexpected credential-access tooling launched from a browser lineage.

Detection Goal	Telemetry Source	Analytic Value	Confidence
Find vulnerable Chrome / Edge versions	EDR software inventory, MDM, vulnerability scanner	High-confidence exposure signal	High
Spot browser activity through untrusted network paths	Proxy, DNS, VPN, EDR network telemetry	Identifies users where privileged-network-position attacks are more plausible	Medium
Correlate repeated browser crashes with network sessions	Windows Error Reporting, EDR DeviceEvents, browser crash telemetry	Weak exploit-adjacent signal; useful when clustered by user, site, or network	Low-Medium
Detect suspicious browser child processes	EDR process telemetry	Higher-confidence post-exploitation signal if browser spawns shell, script host, LOLBin, or payload tooling	Medium
Validate fixed Edge deployment	Microsoft Edge inventory, Intune, Defender TVM	High-confidence remediation evidence	High

Exposure query for Microsoft Defender XDR / Defender Vulnerability Management:

```
// Chrome / Edge versions that should be reviewed for CVE-2026-12012 exposure.
```

```
// Tune software name filters to match local inventory normalization.
DeviceTvmSoftwareInventory
| where SoftwareName has_any ("chrome", "google chrome", "microsoft edge", "edge")
| extend VersionParts = split(SoftwareVersion, ".")
| extend Major = toint(VersionParts[0]), Minor = toint(VersionParts[1]), Build =
toint(VersionParts[2]), Patch = toint(VersionParts[3])
| extend BrowserFamily = case(SoftwareName has "edge", "Microsoft Edge", SoftwareName has "chrome",
"Google Chrome", "Chromium-based browser")
| extend NeedsReview = case(
    BrowserFamily == "Microsoft Edge" and (Major < 149 or (Major == 149 and Build < 4022) or (Major ==
149 and Build == 4022 and Patch < 69)), true,
    BrowserFamily == "Google Chrome" and (Major < 149 or (Major == 149 and Build < 7827) or (Major ==
149 and Build == 7827 and Patch < 115)), true,
    false)
| where NeedsReview
| project DeviceName, BrowserFamily, SoftwareName, SoftwareVersion, EndOfSupportStatus,
RecommendedSecurityUpdate
| order by BrowserFamily asc, SoftwareVersion asc
```

Post-exploitation process lineage hunt:

```
// Browser-spawned shell, script host, or LOLBin activity after the CVE-2026-12012 disclosure window.
DeviceProcessEvents
| where Timestamp > datetime(2026-06-11)
| where InitiatingProcessFileName in~ ("chrome.exe", "msedge.exe", "chromium.exe", "brave.exe",
"opera.exe", "vivaldi.exe")
| where FileName in~ ("cmd.exe", "powershell.exe", "pwsh.exe", "wscript.exe", "cscript.exe",
"mshta.exe", "rundll32.exe", "regsvr32.exe", "certutil.exe", "bitsadmin.exe", "curl.exe", "wget.exe")
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, FileName,
ProcessCommandLine, AccountName, ReportId
| order by Timestamp desc
```

Risky network-path browser activity hunt:

```
// Browser network sessions to infrastructure categories that can place an adversary in a privileged
network position.
// Populate the watchlists with known corporate proxies, VPN egress, and approved inspection devices
before using in production.
let CorporateProxyIPs = (_GetWatchlist('CorporateProxyIPs') | project IPAddress);
let ApprovedVPNEgress = (_GetWatchlist('ApprovedVPNEgress') | project IPAddress);
DeviceNetworkEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("chrome.exe", "msedge.exe", "chromium.exe", "brave.exe",
"opera.exe", "vivaldi.exe")
| where RemoteIPType == "Public"
| where not(RemoteIP in (CorporateProxyIPs)) and not(RemoteIP in (ApprovedVPNEgress))
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Connections=count(),
RemotePorts=make_set(RemotePort, 10), RemoteUrls=make_set(RemoteUrl, 10) by DeviceName,
InitiatingProcessFileName, RemoteIP
| where Connections > 50 or array_length(RemotePorts) > 3
| order by Connections desc
```

Sigma-style exposure and follow-on detection logic:

```
title: Suspicious Child Process From Chromium-Based Browser After CVE-2026-12012 Disclosure
id: 9d7d46e5-5e1d-4f63-8ed7-cve202612012-browser-child-process
status: experimental
description: Detects command shell, script host, and LOLBin child processes launched by Chromium-based
browsers. This does not prove CVE-2026-12012 exploitation, but it is a useful post-exploitation
analytic while browser memory-corruption details remain restricted.
author: Lost Boys Cyber
date: 2026-06-15
references:
- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-12012
- https://chromereleases.googleblog.com/2026/06/stable-channel-update-for-desktop_01962725236.html
logsource:
category: process_creation
product: windows
```

```

detection:
  browser_parent:
    ParentImage|endswith:
      - '\\chrome.exe'
      - '\\msedge.exe'
      - '\\chromium.exe'
      - '\\brave.exe'
      - '\\opera.exe'
      - '\\vivaldi.exe'
  suspicious_child:
    Image|endswith:
      - '\\cmd.exe'
      - '\\powershell.exe'
      - '\\pwsh.exe'
      - '\\wscript.exe'
      - '\\cscript.exe'
      - '\\mshta.exe'
      - '\\rundll32.exe'
      - '\\regsvr32.exe'
      - '\\certutil.exe'
      - '\\bitsadmin.exe'
  condition: browser_parent and suspicious_child
falsepositives:
  - Browser extensions, enterprise SSO helpers, support tools, or legitimate download workflows may
  spawn helper utilities in some environments.
level: medium

```

Threat-hunting hypotheses:

Hypothesis	Hunt Method	Expected Confirmation
Some managed endpoints remain on vulnerable Chrome or Edge builds after the security release	Inventory query by browser version	Devices below fixed version are identified and assigned remediation owners
A network-positioned attacker attempted browser exploitation against users on untrusted networks	Correlate browser crashes, proxy anomalies, and unusual network sessions by user/location	Clusters of crashes or anomalous traffic around the same egress path, SSID, proxy, or user population
A successful exploit led to post-browser execution	Browser child-process and payload-download hunts	Browser lineage to shell/script/LOLBin or new executable download followed by execution

SPL variant for browser child-process review:

```

index=edr sourcetype=process
(parent_process_name IN (chrome.exe, msedge.exe, chromium.exe, brave.exe, opera.exe, vivaldi.exe))
(process_name IN (cmd.exe, powershell.exe, pwsh.exe, wscript.exe, cscript.exe, mshta.exe, rundll32.exe,
regsvr32.exe, certutil.exe, bitsadmin.exe))
| table _time host user parent_process_name parent_process process_name process
| sort - _time

```

7. Recommendations

Priority	Owner	Action	Target Timeline	Evidence of Completion
Critical	Endpoint Engineering	Force-update Google Chrome to a fixed stable build, targeting 149.0.7827.115 or later where available	24-72 hours	EDR / MDM inventory shows no managed Chrome below fixed version
Critical	Endpoint Engineering	Force-update Microsoft	24-72 hours	Edge inventory and

		Edge to 149.0.4022.69 or later		update policy compliance report
High	Vulnerability Management	Inventory Chromium-based browsers beyond Chrome and Edge, including Brave, Opera, Vivaldi, embedded Chromium apps, and portable browsers	7 days	Exception list with owner, version, and remediation plan
High	Security Operations	Deploy the exposure and post-exploitation hunts in this report; tune watchlists for corporate proxy/VPN egress	7 days	Saved queries, reviewed results, documented false positives
Medium	Network Security	Review high-risk privileged network positions: TLS interception devices, captive portals, proxy chains, and unmanaged Wi-Fi used by staff	14 days	Updated network trust boundaries and device ownership records
Medium	IT Operations	Confirm browser auto-update controls cannot be disabled by non-admin users and that stale VDI/golden images are refreshed	14 days	Policy validation and refreshed base images

Compensating controls while patch rollout completes:

- Restrict administrator browsing from privileged workstations and jump hosts.
- Require VPN on untrusted networks for high-value users until fixed browser versions are confirmed.
- Block or alert on unsupported Chromium forks and portable browsers where enterprise update control is absent.
- Increase scrutiny of browser crashes, unusual proxy paths, and browser-spawned scripting utilities during the patch window.
- Treat any confirmed browser child process that launches a shell or script host as an incident-response lead, even if direct linkage to CVE-2026-12012 cannot be proven.

8. References

- [R1] Microsoft Security Update Guide, CVE-2026-12012: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-12012>
- [R2] Microsoft Security Update Guide API record for CVE-2026-12012: <https://api.msrc.microsoft.com/sug/v2.0/en-US/vulnerability/CVE-2026-12012>
- [R3] Microsoft Security Update Guide affected product API record: [https://api.msrc.microsoft.com/sug/v2.0/en-US/affectedProduct?\\$filter=cveNumber%20eq%20%27CVE-2026-12012%27](https://api.msrc.microsoft.com/sug/v2.0/en-US/affectedProduct?$filter=cveNumber%20eq%20%27CVE-2026-12012%27)
- [R4] Google Chrome Releases, Stable Channel Update for Desktop, 2026-06-11: https://chromereleases.googleblog.com/2026/06/stable-channel-update-for-desktop_01962725236.html
- [R5] NVD, CVE-2026-12012: <https://nvd.nist.gov/vuln/detail/CVE-2026-12012>
- [R6] CVE Program record, CVE-2026-12012: <https://www.cve.org/CVERecord?id=CVE-2026-12012>
- [R7] CISA Known Exploited Vulnerabilities Catalog: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [R8] MITRE ATT&CK, T1189 Drive-by Compromise: <https://attack.mitre.org/techniques/T1189/>

- [R9] MITRE ATT&CK, T1557 Adversary-in-the-Middle: <https://attack.mitre.org/techniques/T1557/>
- [R10] MITRE ATT&CK, T1203 Exploitation for Client Execution: <https://attack.mitre.org/techniques/T1203/>